

IBM BOB HACKATHON 2.0

phantomdeps

Prove the dependency claim **before** installation.

A deterministic security gate for AI-assisted development.

The dangerous gap is not the package name

```
// AI Agent generates:  
import { isOddBatch } from 'is-odd';  
  
// Tool invocation:  
npm install is-odd
```

AI coding agents hallucinate package names **and** symbols.

- **Name-existence** checks see 'is-odd' and return **ALLOW**.
- The **symbol** 'isOddBatch' does not exist in the package exports.
- ✗ The build fails **after** the irreversible install.

19.7%

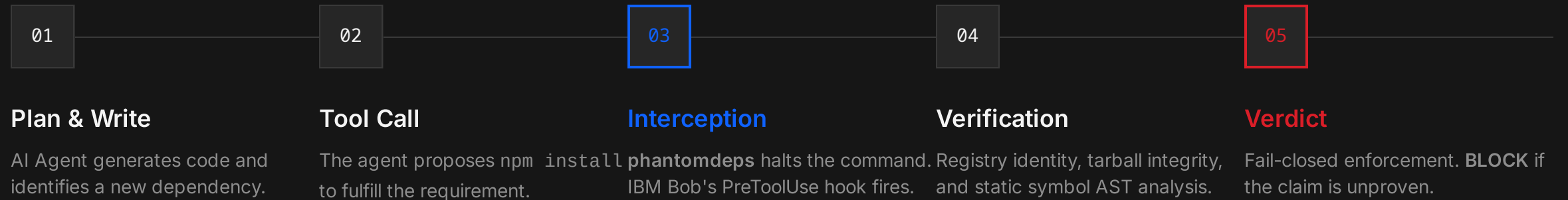
Package-level hallucination rate across 16 popular LLMs.

The GAP

Hallucinated symbols in real packages are the harder failure mode. Traditional CI is too late.

"The package exists, but the function the AI wrote doesn't."

One generated import. One irreversible moment.



Without phantomdeps

Agent installs package → ``npm install`` runs arbitrary lifecycle scripts → build fails on missing symbol → environment is compromised or broken.

With phantomdeps

Interception → byte-level inspection → claim verified or rejected → zero untrusted code execution → **Deterministic Safety**.

A deterministic claim gate, not another assistant

L1

Identity

Registry-level existence check.
Validates exact version and SHA-512 integrity digests against registry packuments.

L2

API Claim

Static AST verification.
Downloads and extracts tarball in-memory to verify symbols in `package.json#exports` and `.d.ts` files.

L3

Risk Signals

Heuristic threat scanning. Flags extreme recency (<7 days) and the presence of lifecycle install scripts.

Log

Provenance

Tamper-evident SHA-256 hash-chained decision records.
Cryptographically verifiable audit trail.

ALLOW

Claim verified.
Safe to install.

WARN

Claim verified.
Risk signals detected.

BLOCK

Hallucination proven.
Halts execution.

UNVERIFIED

Network/Parsing fail.
Fails closed.

Proof: BLOCK before npm runs

```
phantomdeps check is-odd@3.0.1 --symbols isOddBatch

[VERDICT] BLOCK

Package: is-odd@3.0.1
Integrity: sha512-Vvk2j... (VERIFIED)
Claimed symbol: isOddBatch
Finding: 12.symbol_missing – Static API check failed.

The package 'is-odd@3.0.1' exists, but its exports mapping and symbol table do not contain 'isOddBatch'.

No package was installed. No code was executed.

Source: Fixture 'is-odd-demo' (2025-09-20) | SHA-256 Digest: verified
```

L1 IDENTITY	L2 CLAIM	SAFETY
Confirmed is-odd@3.0.1 exists on npm.	AST parsing proved isOddBatch is a hallucination.	Interception occurred at PreToolUse phase.

Block with a reason. Recover with approval.

REMEDIATION CANDIDATE

Static resolver suggests valid symbol: isOdd()

```
- import { isOddBatch } from 'is-odd'  
+ import isOdd from 'is-odd'
```

HUMAN APPROVAL REQUIRED

phantomdeps never auto-applies patches. Every repair plan requires explicit human confirmation before Bob modifies the codebase.

RE-VERIFICATION PATH

The **ALLOW** Path

1. Human approves repair.
2. Bob applies patch to source.
3. Bob runs safe local build/tests.
4. Gate re-verifies install command.
5. **ALLOW**: install proceeds.

VERIFIED OUTCOME

TC-010: Import of merge from lodash@4.17.21 confirmed via static tarball inspection. Result: **ALLOW.**

Built for IBM Bob's moment of action

- INTERCEPTION (L0)

Native PreToolUse Hook

Configured in `.bob/settings.json`. The hook intercepts every `execute_command` matching `npm install` before it ever reaches the shell.

```
"matcher": "execute_command",  
"command": "npx tsx PreToolUse.mjs"
```

- EVIDENCE LEDGER

Hash-Chained Audit Log

Every decision is appended to an NDJSON log with a SHA-256 chain to the previous record. Immutable, verifiable history of agent actions.

```
{ "decisionId": "uuid-001",  
  "action": "BLOCK",  
  "recordHash": "sha256:..." }
```

Plan → Ask → Agent Verified.

IBM Bob is the only AI development partner with the full repository context required to fuel our claim gate. We don't just provide a tool; we provide an honest enforcement boundary for agentic workflows.

The prototype is measurable

205

TESTS PASSING

100%

WRONG-SYMBOL RECALL

0%

FALSE-BLOCK RATE

1168ms

AVG GATE LATENCY

EVALUATION CORPUS RESULTS (B0/B1/B2)

Scenario	Expected	Actual	Rule Citations
Hallucinated symbol in real pkg	BLOCK	BLOCK	12.symbol_missing
Valid import (lodash.merge)	ALLOW	ALLOW	—
New pkg with install scripts	WARN	WARN	13.risk_signal
Registry unavailable / 404	BLOCK	BLOCK	11.not_found

Trust comes from what we refuse to claim

CURRENT SCOPE & BOUNDARIES

- 01** Registry-name specs for npm are first-class; URL, file, and alias forms are currently unverified.
- 02** Static export declarations (ESM/TS) are required for B2 verification; dynamic/CJS exports return **UNVERIFIED**.
- 03** Zero post-approval monitoring; the gate secures the entry point, not the entire lifecycle.

THE ROADMAP TO PRODUCTION

- **Live Symbol Resolution** for dynamic CommonJS exports and non-standard layouts.
- **Enterprise Provenance:** Support for private registries via token/vault integration.
- **L4 Task Fit:** Deep README/intent analysis via isolated subagents for high-ambiguity packages.

Make every AI dependency claim reviewable.

FINAL SUBMISSION ACTIONS

- [01] Review full repository & evidence logs
- [02] Verify evaluation corpus metrics (TC-001-TC-012)
- [03] Authorize final submission to IBM Bob 2.0 Hackathon

github.com/adishxm/phantomdeps

Aditya Kumar Sharma

Narayan Kumar Jha

Utkarsh Yadav

Roshan Singh